

EXECUTIVE BRIEF

Control Design vs. Operating Effectiveness

Why a thoughtfully designed control can still fail - and why consistent activity cannot repair a fundamentally weak design.

Design effectiveness asks whether the control can work. Operating effectiveness asks whether it actually does.

Adapted from the published TechNerd Consulting article

July 2026

TWO DIFFERENT QUESTIONS

A control can pass one test and fail the other

Design effectiveness

If the control is performed as intended, is it reasonably capable of achieving its objective?

Design considers risk linkage, objective, scope, ownership, authority, timing, decision criteria, evidence, exceptions, dependencies, and failure handling.

Operating effectiveness

Was the implemented control actually performed as designed over the relevant period?

Operation considers consistency, timing, competence, authority, execution, evidence, exceptions, follow-through, and whether the expected result occurred.

	Operates effectively	Operates ineffectively
Designed effectively	Dependable control Capable design and reliable operation.	Execution failure Sound structure, but performance breaks down.
Designed ineffectively	Consistent weakness The process runs as written, but the written design cannot achieve the objective.	Control failure Structural and operational weaknesses both exist.

ACCESS REVIEW EXAMPLE

Completion is an activity metric - not an assurance conclusion

A quarterly review launches on schedule, managers submit decisions, the dashboard reaches 100 percent, and the evidence package is retained. The control may still fail.

Incomplete population

Locally managed accounts, direct entitlements, nested groups, or disconnected applications never enter the review.

Wrong reviewer or weak context

A manager may know the person but not understand the technical access, risk, or application purpose.

Weak decision criteria

Reviewers are told to approve or revoke without clear standards, business context, ownership, or exception rules.

No verified remediation

Rejected access creates a task, but removal is not reconciled to the target system or effective-access state.

Perfect execution of an incomplete design reproduces the same weakness with impressive consistency.

EVALUATE DESIGN

Is the control capable of achieving its objective?

Risk and objective

Does the control address a defined risk and describe the intended outcome rather than only the activity?

Scope and completeness

Are relevant systems, populations, identities, transactions, and access paths included? Are exclusions explicit?

Ownership, authority, and context

Are accountability, operational responsibility, and decision authority assigned to people with sufficient knowledge?

Frequency, timing, and triggers

Are timing and frequency appropriate to risk, and can missing or delayed triggers be detected?

Dependencies and failure paths

Are upstream data, system interfaces, manual handoffs, failures, escalation, and recovery considered?

Evidence and follow-through

Can the design produce evidence that supports the outcome, including remediation, exceptions, and closure?

EVALUATE OPERATION

Did the control perform reliably during the period?

Occurrence and consistency

Did the control operate at the required times and across the relevant period, not only in selected examples?

Correct population and inputs

Did actual executions use complete, accurate, timely, and authorized populations and source data?

Competence and authority

Did operators and reviewers have the access, knowledge, independence, and authority required by the design?

Decision and exception quality

Were decisions supported, exceptions governed, and overdue or disputed items escalated?

Remediation and outcome

Were rejected or failed items corrected within required timeframes, and was the resulting condition verified?

Evidence integrity

Is evidence complete, traceable, contemporaneous, reproducible where appropriate, and consistent with the conclusion?

Match the remedy to the weakness. Redesign incomplete controls; improve execution where the design is sound; address both when structural and operational weaknesses coexist.

CONTROL WALKTHROUGH

Questions that prevent the wrong conclusion

- What risk and outcome does the control address?
- Could the control achieve that outcome if performed exactly as designed?
- How is population completeness established and reconciled?
- Who is accountable, who operates the control, and who makes decisions?
- What knowledge and authority must reviewers possess?
- What triggers, timing requirements, dependencies, and failure paths exist?
- What evidence supports both activity and outcome?
- How are rejected items, failures, exceptions, and remediation verified through closure?
- Was the control consistently effective across the relevant period?
- Does the proposed correction address design, operation, or both?

Read the full article

technerd.tech/insights/control-design-vs-operating-effectiveness/

This brief is educational material and does not constitute an audit opinion or organization-specific control assessment.



Selected authoritative references

PCAOB AS 2201, *An Audit of Internal Control Over Financial Reporting That Is Integrated with An Audit of Financial Statements*: pcaobus.org/.../AS2201. The standard is specific to ICFR; this brief uses its design-and-operation distinction as a practical analytical concept, not as a universal cybersecurity requirement.

NIST SP 800-53 Rev. 5: csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

NIST SP 800-53A Rev. 5: csrc.nist.gov/pubs/sp/800/53/a/r5/final